

INFORME NIST AI RISK MANAGEMENT FRAMEWORK

Tendencias 2024-2026, Indicadores de Ciberseguridad Territorial (España) e Implicaciones de Resiliencia Digital

Preparado por: Consorcio de Científicos de Datos, Estrategas de Ciberseguridad y Especialistas en Resiliencia Digital

Clasificación: Investigación Institucional de Alto Nivel

Fecha: Enero 2026

Distribución: Ejecutivos de Riesgo, Responsables de Gobernanza IA, Autoridades Regulatorias

EXECUTIVE SUMMARY

El **NIST Artificial Intelligence Risk Management Framework (AI RMF)** ha evolucionado desde su lanzamiento en enero 2023 hacia un ecosistema integrado de marcos complementarios que abordan IA generativa, ciberseguridad de componentes IA, y defensa resiliente frente a ataques basados en IA. En paralelo, **España** ha acelerado su marco regulatorio mediante la transposición del Reglamento (UE) 2024/1689 (Ley de IA), la implementación de la Directiva NIS2, y la creación de la Agencia Española de Supervisión de Inteligencia Artificial (AESIA).

Hallazgos clave:

1.
Convergencia Normativa Global: NIST AI RMF, EU AI Act, e ISO/IEC 23894 comparten principios de trustworthiness pero con enfoques distintos—NIST (voluntario, flexible) vs. EU (obligatorio, prescriptivo).
2.
Capacidad Territorial Española: Posición 15º global (NCSI 89.17/100), con marco legal robusto pero retos de implementación en SMEs; inversión de €1.157M (2025-2026) en ciberseguridad.
3.
Métricas Emergentes: El NIST formaliza siete características de trustworthiness (valid, safe, secure, accountable, explainable, privacy-enhanced, fair) con énfasis en medición continua y no solo conformidad estática.
4.
Vulnerabilidades de Cadena Suministro IA: 512.847 paquetes malignos detectados (↑156% YoY); data poisoning, model extraction, y compromiso CI/CD identificados como vectores prioritarios de ataque (2024-2026).
5.
Resiliencia Digital + AI: Integración de IA en recovery operacional reduce costos de brechas en €2.44M promedio; pero requiere gobernanza clara, human-in-the-loop (80% colaboración), y fallbacks críticos.

Convergencia Normativa Global: NIST AI RMF, EU AI Act, e ISO/IEC 23894 comparten principios de trustworthiness pero con enfoques distintos—NIST (voluntario, flexible) vs. EU (obligatorio, prescriptivo).

Capacidad Territorial Española: Posición 15º global (NCSI 89.17/100), con marco legal robusto pero retos de implementación en SMEs; inversión de €1.157M (2025-2026) en ciberseguridad.

Métricas Emergentes: El NIST formaliza siete características de trustworthiness (valid, safe, secure, accountable, explainable, privacy-enhanced, fair) con énfasis en medición continua y no solo conformidad estática.

Vulnerabilidades de Cadena Suministro IA: 512.847 paquetes malignos detectados (↑156% YoY); data poisoning, model extraction, y compromiso CI/CD identificados como vectores prioritarios de ataque (2024-2026).

Resiliencia Digital + AI: Integración de IA en recovery operacional reduce costos de brechas en €2.44M promedio; pero requiere gobernanza clara, human-in-the-loop (80% colaboración), y fallbacks críticos.

I. EVOLUCIÓN NIST AI RMF: TIMELINE 2023-2026

A. Versiones y Actualizaciones Publicadas

Versión	Fecha	Scope	Relevancia para España
AI RMF 1.0	Enero 2023	Cuatro funciones core (GOVERN, MAP, MEASURE, MANAGE); siete características de trustworthiness	Referencia técnica; base para EU AI Act alignment
NIST CSF 2.0	Febrero 2024	Six functions (GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER); integración AI explícita	Ciberseguridad crítica + resiliencia; guía para ENS actualizado
GenAI Profile (AI 600-1)	Abril 2024	400+ acciones mitigación para LLMs/GenAI; riesgos amplificados (hallucinations, jailbreaking)	Regulaciones futuras de IA generativa en sector público/privado
Cyber AI Profile (Draft)	Enero 2026	Tres ejes: Secure (componentes IA), Defend (IA defensiva), Thwart (resiliencia ad ataq IA)	Integración con NIS2; guidance operativa para SOC's España

B. Drivers de Actualización

- Regulación EU AI Act: Convergencia NIST → EU normativa (art. 28-99 operativos Q2 2026)
- GenAI Mainstream: Detección de riesgos únicos no previstos en v1.0 (prompt injection, model poisoning, data leakage)
- Supply Chain Attacks: OpenAI + NSA/CISA (2024) documentan threat actors usando LLMs para malware development
- Governance Imperativo: Mayores exigencias de Board-level oversight, E-Risk integration, audit readiness

II. INDICADORES Y MÉTRICAS: DIMENSIONES DE CIBERSEGURIDAD EN NIST AI RMF

A. Las Siete Características de Trustworthiness (NIST AI RMF 1.0)

El framework define trustworthiness como balance multidimensional de propiedades técnicas, operacionales y éticas. **Valid & Reliable** es condición necesaria; **Accountable & Transparent** span todas las demás.

1. Valid & Reliable (Validez y Confiabilidad)

- Definición: Exactitud, robustez, generalización más allá de condiciones de entrenamiento
- Métricas NIST Sugeridas:
- Precision, recall, F1-score
- External validity índices (generalización a datos no vistos)
- Disaggregation por demografías/segmentos
- Riesgo de No Cumplimiento: Deployments en producción con accuracy no verificada → 23% de las querellas regulatorias (NIST survey, 2024)

2. Safe (Seguridad Operacional)

- Definición: Ausencia de condiciones que causen daño a vida, salud, propiedad o ambiente
- Métricas NIST Sugeridas:
- Mean Time to Recover (MTTR) de fallos
- Residual risk documentado post-mitigación
- Incident response time < 15 min (crítica)
- Criticidad España: Sectores sanitario (diagnosis), transporte (autónomo), energía (SCADA)

3. Secure & Resilient (Seguridad y Resiliencia)

- Definición: Resistencia a ataques; confidencialidad, integridad, disponibilidad preservadas
- Métricas NIST Sugeridas:
- Model extraction detection rate
- Breach incidents / total deployments
- Mean Time to Detect (MTTD) de anomalías
- Vector Crítico 2024-2026: Data poisoning en training sets; AI supply chain vulnerabilities

4. Accountable & Transparent (Responsabilidad y Transparencia)

- Definición: Trazabilidad de decisiones; roles/responsabilidades definidos; documentación accesible
- Métricas NIST Sugeridas:
- Completitud de audit trails (100%)
- Response time a solicitudes de acceso (GDPR/AESIA compliance)
- Frequency de reportes independientes
- Normativa España: Obligatorio bajo EU AI Act Art. 50 (agosto 2026)

5. Explainable & Interpretable (Explicabilidad e Interpretabilidad)

- Definición: Comprensión por usuarios/operadores del mecanismo y outputs del modelo
- Métricas NIST Sugeridas:
- Explanation quality scores (user study basado)
- Feature importance audits
- SHAP/LIME coverage % de outputs
- Caso de Uso España: Decisiones de elegibilidad en beneficios sociales (SSAA)

6. Privacy-Enhanced (Privacidad Mejorada)

- Definición: Protección de datos personales y autonomía individual
- Métricas NIST Sugeridas:
- Data minimization ratio (inputs/outputs reduced)
- Privacy-enhancing technology (PET) implementation %
- Privacy incident rate / year
- Compliance España: RGPD + LOPD/LPDGDD; NIS2 data protection obligations

7. Fair – with Harmful Bias Managed (Equidad y Bias Controlado)

- Definición: Mitigación de sesgos sistémicos, computacionales, cognitivos humanos
- Métricas NIST Sugeridas:
- Fairness metrics (demographic parity, equalized odds)
- False positive disparity < 5% entre grupos
- Bias audit frequency (mínimo anual)
- Disparate impact analysis
- Criticidad España: Hiring algorithms, creditworthiness assessments, criminal risk scoring

B. Función MEASURE: Operacionalización de Métricas

El framework formaliza **MEASURE** en cuatro subcategorías:

Subcategoría	Actividad	Output Esperado
MEASURE 1	Identificar & aplicar métodos de medición	Matriz de riesgos priorizada; gaps documentados
MEASURE 2	Evaluar trustworthiness characteristics	Reportes de TEVV (Test, Evaluation, Validation, Verification); scores por característica
MEASURE 3	Tracking de riesgos emergentes	Risk register actualizado; incidentes no anticipados catalogados
MEASURE 4	Validación de eficacia de medición	Feedback loops integrados; mejoras documentadas

Hallazgo Crítico: NIST NO prescribe métricas numéricas específicas. Desafía a orgs a contextualizar basado en: (a) sector, (b) use case, (c) stakeholders, (d) disponibilidad de métodos probados.

III. CONTEXTO TERRITORIAL ESPAÑA: MARCO REGULATORIO E INDICADORES

A. Normativa Vigente y En Transposición (2024-2026)

1. Reglamento (UE) 2024/1689 (Ley de IA)

- Entrada en vigor: Capítulos I-II: 2 febrero 2026
- Artículos operativos progresivos:
- Art. 50 (Transparencia): Agosto 2026 – Obligación de informar usuarios sobre interacción IA
- Art. 28-99 (Conformidad, sanciones): Esperado Q2 2026
- Sanciones: €35M o 7% volumen negocio (infracciones muy graves)
- Autoridad de Vigilancia España: Agencia Española de Supervisión de IA (AESIA) – creada marzo 2025

2. Directiva NIS2 (Transposición Españ: Royal Decree 443/2024 + ENS)

- Fecha vigencia España: 17 octubre 2024; transposición legislativa hasta enero 2025
- Scope: Entidades esenciales e importantes en 12 sectores críticos (energía, transporte, salud, telecomunicaciones, etc.)
- Obligaciones clave:
- Evaluación periódica de riesgos ciberseguridad
- Implementación de medidas de gestión de riesgos
- Notificación de incidentes (< 72 horas)
- Auditorías independientes
- Sanciones NIS2: €10-20M o 2-4% volumen anual

3. Estrategia Nacional de IA (2024) + Plan Nacional Ciberseguridad (Actualización 2025-2026)

- Coordinador: Secretaría de Estado de Digitalización e IA (SEDIA)
- Inversión: €1.157 millones (ciberseguridad + resiliencia digital)
- Iniciativas:
- Integración IA en SOC (Security Operations Centers) nacionales
- Red de Competencia Nacional (NCC-ES) – mirror de ECCC europeo
- Sandbox regulatorio para high-risk AI systems
- Centros de excelencia (R&D en ciberseguridad + IA)

B. Indicadores de Ciberseguridad Nacional (2024)

Métrica	Valor	Tendencia
Posición NCSI Global	15ª (89.17/100)	Estable vs. 2023
Incidentes Detectados (2024)	97.348	↑ 16.6% YoY
Incidentes en Empresas	31.540 (32% del total)	↑ 43.2% YoY
Sistemas Vulnerables Expuestos	183.851	Crítica: vulnerabilidades OT amplificadas
Incidentes Críticos (Sector Público, 2022)	~70 de 55.000	60% cybercrime groups; 40% state-sponsored
Tiempo Promedio Compromiso → Detección	48 minutos	Benchmark CrowdStrike global

C. Capacidad Institucional: INCIBE como Pilar

Rol Estratégico:

- Respuesta a incidentes (INCIBE-CERT)
- Supervisión NIS2 (para operadores críticos)
- Investigación & desarrollo (Red RENIC)
- Capacitación (INCIBE Emprende, Hacker Academy)

Fortalezas: Marco legal alineado, institución técnica consolidada, inversión creciente

Brechas: Capacidad SMEs limitada, velocidad implementación regulatoria, métricas AI aún inmaduras

IV. VULNERABILIDADES EMERGENTES EN IA: CADENA SUMINISTRO Y OPERACIONAL (2024-2026)

A. Supply Chain AI Risks (Crítico)

Contexto: 512.847 paquetes malignos en repositorios open-source detectados en 2024 (↑156% YoY).

Python es lenguaje de más rápido crecimiento con vulnerabilidades per-package.

1. CI/CD Pipeline Compromise

- Mecánica: Inyección maliciosa en pipelines de integración/deployment
- Riesgo: Modelos pre-entrenados distribuidos con puertas traseras
- Mitigation NIST: Cyber AI Profile (Secure función)

2. Data Poisoning

- Mecánica: Contaminación intencional de datasets de entrenamiento
- Riesgo: Modelos que toman decisiones sesgadas/maliciosas post-deployment
- Ejemplo: Modelo de detección de malware entrenado con datos envenenados → ignora variantes específicas
- Métrica NIST: MEASURE 2.11 (fairness evaluation) + 2.4 (safety testing under adversarial conditions)

3. Model Extraction

- Mecánica: Replicación de modelo propietario vía queries repetidas a API
- Riesgo: Theft de intellectual property; compromiso de confidencialidad
- Detección: Anomalía en patrón queries; correlación entrada-salida

4. Prompt Injection & Jailbreaking

- Mecánica: LLMs manipuladas para revelar information restringida o ejecutar acciones no autorizadas
- Riesgo: Bypass de safety controls; data exfiltration
- OWASP Top 10 LLM Risks: Rank 1 (LLM01:2023 Prompt Injection)

B. Threat Actors Documentados (OpenAI + NSA/CISA, 2024)

Tres grupos identificados:

1. **Chinese APT**: Scripting, vulnerability analysis vía ChatGPT
2. **Iranian APT (Group 1)**: Custom bash/Python malware development
3. **Iranian APT (Group 2)**: Android malware obfuscation, C2 communications

Impacto: Escalado significativo de capacidades ofensivas; tiempo-a-explotación reducido

V. NIST AI RMF VS. MARCOS INTERNACIONALES: PERSPECTIVA COMPARATIVA

A. Matriz de Comparación (NIST vs. EU AI Act)

Dimensión	NIST AI RMF	EU AI Act (RIA 2024/1689)	Híbrido Óptimo (España)
Naturaleza Legal	Voluntario (orientativo)	Obligatorio (legal)	Dual: voluntario + conformidad verificable
Enfoque Riesgo	Flexible, context-driven	Pirámide: prohibido, alto, limitado, mínimo	Mapped: NIST MAP → EU risk classification
Transparencia	Recomendada (MEASURE 2.8)	Mandatoria Art. 50 (agosto 2026)	Obligatorio con NIST-defined metrics
Supply Chain	Orientación emergente (GenAI Profile)	Requiere trazabilidad (Art. 28-29)	Cyber AI Profile + EU conformity docs
Auditoría	Interna recomendada	Externa mandatoria (Notified Bodies)	Ambas: interna (NIST), externa (AESIA)
Sanciones	N/A (framework guidance)	€35M o 7% volumen	EU sanciones + reputacional (NIST no-conformidad)

B. Convergencia Global: ISO/IEC Frameworks

ISO/IEC 23894:2023 (AI Risk Management) alinea con:

- NIST AI RMF (funciones análogas: Map/Identify/Assess)

- ISO 31000:2018 (ERM principles)
- ISO/IEC 42001 (AI Management Systems)

España debe: Mapear NIST – EU AI Act – ISO 23894 para compliance integrada (no triple documentación)

VI. MÉTRICAS DE RESILIENCIA DIGITAL + CONTINUIDAD DE NEGOCIO CON IA

A. Integración IA en Disaster Recovery (IDC/CyberEdge, 2024)

Hallazgo Principal: Empresas con automatización AI-driven en recovery reportan €2.44M de ahorro promedio en costos de brechas.

1. Detección Predictiva (Anomaly Detection)

- Métrica: MTTD (Mean Time to Detect) < 15 minutos
- Capabilidad: Comportamiento anómalo (credential stuffing, firmware corruption)
- ROI: Pre-staging de fixes; aislamiento de segmentos vulnerables

2. Automatización de Recovery

- Métrica: Validación de integridad de backups pre-restauración; rerouting automático de red
- Capabilidad: Simultaneous detection – decisioning – orchestration (segundos vs. horas manuales)
- Caso de Uso España: Recovery de sistemas SCADA en sector energía

3. Human-AI Collaboration (10-80-10 Model)

- 10%: Decisiones totalmente automatizadas (incident classification basic)
- 80%: Colaboración hybrid (AI sugiere acciones; human valida/refina)
- 10%: Decisiones humanas puras (ethical dilemmas, crisis politics)

B. Resiliencia Operacional: Modelo ISACA 2025

Riesgos AI en Resiliencia:

1. **AI Agents Autonomous:** Pueden fallar sin intervención humana – fallbacks requeridos
2. **Synthetic Data Testing:** Prepara equipos contra interrupciones no experimentadas
3. **Self-Healing Systems:** "Good AI" vs. "Bad AI" arms race en detección/evasión

C. Casos de Uso España: Sectores Críticos

Sector Energía (Red Eléctrica Ibérica)

- Riesgo: Fallo de SCADA → blackout nacional (precedente: abril 2025, outage Iberia)
- NIST Aplicación: GOVERN (políticas fail-safe), MEASURE (anomaly detection en OT), MANAGE (recovery orchestration)
- Métrica Resiliencia: RTO < 4 horas; RPO < 15 minutos

Sector Salud (Hospitales)

- Riesgo: Ransomware en sistemas diagnosis → unavailable clinical workflows
- NIST Aplicación: MAP (stakeholder impact modeling), MEASURE (performance under stress), MANAGE (incident communication)
- Métrica Resiliencia: Continuidad de operaciones críticas $\geq 95\%$; backup systems activados < 5 min

Sector Transporte (Renfe, Aeropuertos)

- Riesgo: IA de navegación/scheduling comprometida → disruption masiva
- NIST Aplicación: Secure (model integrity verification), Defend (detection de anomalías en outputs)
- Métrica Resiliencia: Redundancia de sistemas críticos; human override capability

VII. RECOMENDACIONES ESTRATÉGICAS: ESPAÑA 2026-2028

A. Para Autoridades Regulatorias (AESIA, INCIBE, SEDIA)

10. Publicar Guía de Mapeo Normativo (Q2 2026)
11. NIST AI RMF funciones → EU AI Act Artículos
12. Checklist de cumplimiento dual para operadores
13. Ejemplos sector-específicos (sanitario, energía, transporte)
14. Extender ENS (Esquema Nacional Seguridad) con AI-specific Controls
15. Integrar MEASURE function de NIST
16. Requerir documentación de trustworthiness characteristics
17. Audit trail completeness (100%) como baseline
18. Desarrollar Métricas de Sector
19. Energía: Anomaly detection benchmark para SCADA
20. Salud: Accuracy/fairness thresholds para sistemas diagnosis
21. Transporte: Safety metrics para autonomous systems
22. Publicar anualmente (similar a CIS Benchmarks)

Ejemplos sector-específicos (sanitario, energía, transporte)

Extender ENS (Esquema Nacional Seguridad) con AI-specific Controls

Audit trail completeness (100%) como baseline

Desarrollar Métricas de Sector

B. Para Sector Privado (Operadores Críticos & SMEs)

23. Operadores Esenciales: Implementar NIST GOVERN + MAP antes de 2027 (preemptive)
24. Formar AI Governance Committee (Board-level oversight)
25. Documentar AI use case inventory con riesgo classification
26.
Establecer risk tolerance statements por categoría
27.
Programa SME Acelerado (INCIBE + CDTI)
28. Financiamiento para implementación NIST Measure/Manage
29. Mentoring de peers (large org. mentors SME)
30.
Certificación de madurez IA (roadmap a ISO/IEC 42001)
31.
Supply Chain Security
32. Auditar modelos pre-entrenados (provenance, tampering detection)
33. Implementar Cyber AI Profile (Secure función) para CI/CD
34. Participar en threat intelligence sharing (INCIBE-CERT channels)

Establecer risk tolerance statements por categoría

Programa SME Acelerado (INCIBE + CDTI)

Certificación de madurez IA (roadmap a ISO/IEC 42001)

Supply Chain Security

C. Para Investigación & Academia

35. Centros de Excelencia NIST
 36. UAM, UPM, UC3M: Laboratorios de evaluación AI RMF
 37. Investigación en métricas de fairness/robustness contextualizadas
 38.
Publicaciones en venues de referencia (NDSS, USENIX Security, AAAI)
 39.
Proyectos CDTI Alineados
 40. "Detección de Data Poisoning en Cadena Suministro IA"
 41. "Auditoría de Model Extraction: Defenses & Detection"
 42.
"Framework de Resiliencia IA para Infraestructura Crítica"
 43.
Colaboración Internacional
 44. Participación en NIST AI Resource Center (AIRC)
 45. Benchmarking vs. Alemania (BSI), Francia (ANSSI), Holanda (NCSC)
- Publicaciones en venues de referencia (NDSS, USENIX Security, AAAI)

Proyectos CDTI Alineados

"Framework de Resiliencia IA para Infraestructura Crítica"

Colaboración Internacional

VIII. CONCLUSIONES Y OUTLOOK 2026-2028

A. Convergencia de Marcos

Síntesis Estratégica: España está bien posicionada para adoptar NIST AI RMF como **herramienta técnica de implementación** del EU AI Act—no como alternativa, sino como **enabling mechanism**. La madurez normativa española (AESIA, INCIBE, ENS) proporciona infraestructura institucional.

B. Riesgos Críticos No Mitigados

46. Velocity Gap: Amenazas de IA evolucionan más rápido que regulación (GenAI, agentic AI)
47. SME Capacity Gap: 80% de SMEs requieren asistencia para NIST compliance
48. Supply Chain Opacity: Malicious ML packages en repositorios público-privados aún no diferenciables confiablemente

C. Oportunidades Diferenciadores

49. EU Leadership: España puede ser hub de implementación NIST en Europa (benchmark para Francia, Italia)
50. Digital Sovereignty: Desarrollo de herramientas/metodologías de evaluación AI "made in Spain"
51. Sector Crítico Innovation: Modelos de resiliencia IA-driven para energía/transporte/salud

D. Timeline Crítico: 2026

Hito	Responsable	Impacto
Feb 2026	AESIA	Entrada completa EU AI Act operativo
Apr 2026	INCIBE/SEDIA	Publicación Guía NIST – EU AI Act Compliance
Jun 2026	Sector Privado	Deadline auto-auditoría sistemas high-risk
Aug 2026	Operadores Todo Sector	Obligación Art. 50 (transparencia usuarios)
Q4 2026	NIST	Finalización Cyber AI Profile; potential v2.0 roadmap

ANEXO: REFERENCIAS PRIMARIAS

Documentación Oficial Consultada:

- NIST AI 100-1 (AI RMF 1.0, enero 2023)
- NIST CSWP 29 (CSF 2.0, febrero 2024)
- NIST AI 600-1 (GenAI Profile, abril 2024)
- NIST Cyber AI Profile (Draft, enero 2026)
- Reglamento (UE) 2024/1689 (Ley de IA)
- Directiva (UE) 2022/2555 (NIS2)
- Anteproyecto Ley Orgánica IA España (11 marzo 2025)

Instituciones Españolas:

- INCIBE (Instituto Nacional Ciberseguridad)
- AESIA (Agencia Española Supervisión IA)
- SEDIA (Secretaría Estado Digitalización e IA)
- CCN-CERT (Centro Criptológico Nacional)

Benchmarks Internacionales:

- NCSI (National Cyber Security Index): España 15º; Holanda 6º; Alemania 7º
- IDC/CyberEdge State of DR 2024-2025
- Palo Alto Networks Global Incident Response Report 2025

Fuentes Académicas & Técnicas:

- OpenAI Research (LLM Security, Threat Actor Capabilities)
- NSA/CISA Joint Security Alerts (2024)

- Cloud Security Alliance (AI Security Threats)
- Brookings Institution (NIST Framework Policy Analysis)

Documento Preparado: Enero 2026

Próxima Revisión Recomendada: Octubre 2026 (post-entry-en-vigor EU AI Act completo)